

# VULNERABILITY DISCLOSURE REPORT

## WAF Path Normalization & Filter Bypass

Target Product: [REDACTED] Web Application Firewall  
Report Date: May 05, 2026  
Researcher: Amin Hisham Shembesh

Classification: **CONFIDENTIAL — FOR [REDACTED]**  
**SECURITY TEAM ONLY**

### 1. Researcher Information

|                 |                                                                                                          |
|-----------------|----------------------------------------------------------------------------------------------------------|
| Full Name       | Amin Hisham Shembesh                                                                                     |
| Role / Title    | Junior Penetration Tester & SOC Analyst   B.S. Candidate, Computer Science & Engineering (Cybersecurity) |
| [REDACTED]      | [REDACTED]                                                                                               |
| LinkedIn        | linkedin.com/in/amin-shembesh-4aab5a250                                                                  |
| Disclosure Type | Responsible / Coordinated Disclosure                                                                     |

### 2. Executive Summary

During an authorized security assessment, I identified a logic-level vulnerability in the [REDACTED] Web Application Firewall (WAF). The flaw relates to insufficient URL path normalization prior to signature matching and rule enforcement.

The WAF fails to canonicalize certain URL path sequences before evaluating incoming requests against its security rule set. As a result, an attacker can craft specially formed URLs that bypass WAF protections entirely, while the underlying backend server still processes the request. This represents a failure in the WAF's primary function as a perimeter defense layer.

Two specific bypass techniques were confirmed:

- Double-slash prefix injection (e.g., //env, //config) bypasses path-based WAF rules.
- Semicolon-dot path injection (e.g., ././admin, /manager/./status) bypasses access control filters.

This report focuses exclusively on the logic flaw within the [REDACTED] WAF product itself. All testing was conducted in the context of an authorized engagement, and this disclosure is made in good faith to assist in improving the product's security.

### 3. Finding Summary

| Finding                     | Severity | Component Affected     | Status    |
|-----------------------------|----------|------------------------|-----------|
| Path Normalization Bypass   | HIGH     | WAF Rule Engine        | Unpatched |
| Double-Slash Filter Evasion | HIGH     | WAF URL Parser         | Unpatched |
| ././ Sequence Bypass        | HIGH     | WAF Signature Matching | Unpatched |